

UNIVERSITY OF MINES AND TECHNOLOGY, TARKWA
FACULTY OF COMPUTING AND MATHEMATICAL SCIENCES
DEPARTMENT OF CYBERSECURITY AND INFORMATION SYSTEMS



SEMESTER PROJECT REPORT ENTITLED
Designing a Threat Intelligence Sharing Process With Industry Peers

(ISAC MODEL)

Submitted by

OTU ABOAH DENNIS

FCM.41.018.223.23

Course: Network Security, Auditing and Monitoring

Course Instructor: Mr. Frederick Edem Broni

August 2026

Abstract

Organizations that share an industry also share adversaries, yet most defend against cyber threats in isolation. This project designs and implements a threat intelligence sharing process modelled on real-world Information Sharing and Analysis Centres (ISACs), addressing the governance, classification, and workflow problems that make peer-to-peer threat sharing difficult in practice. The design defines a six-stage sharing lifecycle, a four-tier Traffic Light Protocol (TLP) classification scheme, and a governance model built around a neutral operator and rotating steering committee. A working reference application, named Sentinel ISAC, was built to demonstrate the process end-to-end: members can submit threat reports, duty analysts can triage and approve them for community dissemination, and the system enforces sanitization of submitter identity unless explicitly disclosed. The report concludes that the technical building blocks for threat sharing — structured data formats, transport protocols, and classification schemes — are already mature; what determines whether an ISAC succeeds is trust, governance, and a workflow simple enough for security teams to use under pressure.

Table of Contents

Abstract	i
1. Introduction	1
1.1 Background	1
1.2 Problem Statement	1
1.3 Objectives	2
1.4 Scope of the Project	2
2. Background and Related Concepts	3
2.1 Information Sharing and Analysis Centres	3
2.2 Relevant Data and Transport Standards	3
3. Problem Analysis	4
3.1 Repeated Exposure	4
3.2 Delayed Awareness	4
3.3 Absence of a Shared Channel	4
3.4 Underlying Barriers to Sharing	5
4. System Design	5
4.1 Design Goals	5
4.2 Governance Model	6
4.3 The Sharing Lifecycle	6
4.4 Classification Scheme (Traffic Light Protocol)	7

4.5 Data Model	7
5. Implementation	8
5.1 Technology Stack	8
5.2 Application Architecture	9
5.3 Key Features Implemented.....	9
5.4 User Interface Walkthrough	10
6. Results and Demonstration	11
6.1 Demonstration Scenario	11
6.2 Observed Outcomes.....	12
7. Limitations and Future Work.....	12
8. Conclusion	13
References.....	13

1. Introduction

1.1 Background

Cyberattacks rarely target a single organization in isolation. Phishing kits, malware droppers, and command-and-control infrastructure are commonly reused across multiple victims within the same industry before defenders across that industry become aware of the pattern. A financial institution that detects and quietly remediates an intrusion today provides no protection to a peer institution that will be hit by the same campaign next week, unless the two organizations have a mechanism to share what they observed.

Information Sharing and Analysis Centres (ISACs) exist to close this gap. An ISAC is a trusted, usually sector-specific community in which member organizations report threats and suspicious activity to a neutral operator, who sanitizes the submission and distributes the actionable portion to the wider membership. Established examples include FS-ISAC (financial services), H-ISAC (healthcare), E-ISAC (electricity) and MS-ISAC (state and local government), each demonstrating that structured, trusted sharing meaningfully improves collective defence within a sector.

1.2 Problem Statement

Despite the demonstrated value of ISACs, establishing an effective sharing process is difficult. The obstacles are rarely technical; they are questions of trust, liability, and workflow. Organizations are reluctant to disclose that they were compromised, particularly to direct competitors. Legal exposure around what can be shared, and with whom, is often unclear. And even organizations that are willing to cooperate frequently lack a common format, a trusted intermediary, or an agreed set of rules for how widely a given piece of information may travel.

This project addresses the question: how can a sharing process be designed so that organizations can disclose what they observed, without being forced to disclose who they are, and with clear, respected rules for how far that information may spread?

1.3 Objectives

- Design a governance model and a sharing lifecycle appropriate for a sector-based ISAC.
- Define a classification scheme that allows submitters to control how widely their information is shared.
- Specify a data model for threat indicators consistent with industry-standard formats.
- Implement a working reference application that demonstrates the full sharing lifecycle end-to-end.
- Evaluate the design against real-world constraints and identify what a production deployment would still require.

1.4 Scope of the Project

The project covers the design of the governance model, the sharing workflow, and the classification scheme, together with a functional prototype implementing member submission, analyst triage, dissemination, emergency broadcast, and program-health reporting. The prototype is a client-side reference implementation intended to demonstrate the process rather than a production-grade, multi-tenant system; Section 7 details what a production deployment would add.

2. Background and Related Concepts

2.1 Information Sharing and Analysis Centres

An ISAC operates on a simple principle: a threat observed by one member is far more valuable to the community than it is to that member alone, provided it can be shared quickly and safely. The neutral operator is central to this — by acting as an intermediary rather than allowing members to report directly to one another, the operator can strip identifying detail from a submission before it is redistributed, removing much of the reputational risk that would otherwise discourage reporting.

2.2 Relevant Data and Transport Standards

Three standards, developed independently of any single ISAC, underpin most modern threat-sharing infrastructure and directly informed the design of this project.

STIX (Structured Threat Information eXpression). A structured, machine-readable format for describing threat information — indicator type, value, severity, and related context — as discrete fields rather than free text, allowing recipient systems to ingest and act on a report automatically rather than requiring manual interpretation.

TAXII (Trusted Automated eXchange of Indicator Information). A transport-layer specification defining how STIX-formatted content is requested, subscribed to, and pushed between systems, enabling automated feeds rather than manual, ad hoc distribution such as email.

TLP (Traffic Light Protocol). A four-level classification scheme, maintained by FIRST.org, that governs how far a piece of shared information is permitted to travel once received, independent of its data format or transport mechanism.

The relationship between the three is complementary rather than overlapping: STIX defines what the shared content looks like, TAXII defines how it moves between organizations, and TLP defines who is permitted to see and re-share it once received. This project adopts STIX-inspired structuring for its data model and TLP for its classification scheme; full TAXII transport automation is identified as a production extension in Section 7.

3. Problem Analysis

Three related failure modes motivate the design decisions in Section 4.

3.1 Repeated Exposure

The same phishing kits, malware droppers, and credential-stuffing infrastructure are frequently reused against multiple victims in the same sector before the pattern is recognized, because no single victim has visibility into what is happening to their peers.

3.2 Delayed Awareness

A single organization typically detects and quietly remediates an incident on its own timeline. Peer organizations struck by the identical campaign days or weeks later begin their investigation with no prior warning, effectively starting from zero.

3.3 Absence of a Shared Channel

Even organizations willing to cooperate frequently lack the infrastructure to do so effectively: no common data format, no trusted intermediary to route submissions through, and no agreed rule set governing what may be disclosed and to whom.

3.4 Underlying Barriers to Sharing

Beneath these three failure modes sit three more fundamental barriers. Reputational risk discourages organizations from admitting a compromise, particularly to a direct competitor. Legal exposure — real or perceived — around liability and antitrust concerns discourages disclosure outside of a clearly defined, lawful channel. And the absence of a common language means that even willing participants often resort to unstructured methods, such as email attachments, that are slow and cannot be consumed automatically by security tooling. The central design question this project answers are therefore: how can an organization share what it observed without being forced to disclose who it is, and without anyone downstream having to guess what "safe to share" means for a given report?

4. System Design

4.1 Design Goals

- Preserve submitter anonymity by default, while allowing voluntary disclosure.
- Make classification explicit and machine-checkable rather than a matter of individual judgement.
- Keep the workflow simple enough that a busy analyst can use it without friction.
- Separate policy-setting authority (governance) from day-to-day operation (the neutral operator).

4.2 Governance Model

The design defines four roles. A rotating Steering Committee, drawn from member organizations, sets policy, admits and removes members, and resolves disputes. A Neutral Operator runs day-to-day intake, sanitization, and dissemination, ensuring no single member organization controls the pipeline through which all other members' intelligence flows. A Duty Analyst performs the actual triage work — validating, deduplicating, and enriching each submission. Member Organizations submit reports, consume the shared feed, and provide feedback that improves future triage.

4.3 The Sharing Lifecycle

Figure 1 illustrates the six-stage lifecycle a report moves through, from initial submission to community-wide benefit. The lifecycle is represented as a loop rather than a strictly linear pipeline: feedback from stage six can prompt re-triage of a report already disseminated, for example if additional context emerges after initial distribution.



Figure 1. The six-stage threat intelligence sharing lifecycle.

4.4 Classification Scheme (Traffic Light Protocol)

Every report carries a TLP classification, set by the submitter at the point of submission, which determines how far the report is permitted to travel once received. Figure 2 summarizes the four levels as implemented in this project. This is the real, industry-standard TLP definition maintained by FIRST.org, adopted here without modification.



Figure 2. The four TLP classification levels and their distribution rules.

4.5 Data Model

Each submitted report is represented internally as a structured object modelled on STIX conventions: a typed indicator value (for example, an IP address, domain, file hash, URL, or described TTP), a severity rating, a TLP classification, a review status, a submission timestamp,

and an organization field that is withheld from the shared feed unless the submitter explicitly opts into disclosure. Table 1 shows the fields used in the reference implementation.

Field	Description	Example
id	Unique submission identifier	SUB-1042
type	Indicator category	IP Address
value	The indicator itself	185.220.101.47
tlp	Traffic Light Protocol classification	TLP: AMBER
severity	Analyst- or submitter-assessed severity	High
status	Lifecycle state	Approved
org	Submitting organization (withheld unless disclosed)	Withheld
ts	Submission timestamp	08:14

Table 1. Fields of the threat-indicator data object used in the reference implementation.

5. Implementation

5.1 Technology Stack

- Frontend: React, styled to a dark, console-style interface appropriate for a security operations context.
- Icon set: lucid-react.
- Data structuring: STIX-inspired indicator objects (see Table 1).

- Classification and access control: TLP tag gates visibility; organization identity withheld by default.

5.2 Application Architecture

The reference implementation, named Sentinel ISAC, is a single-page application with two role-based views. In the Member view, a user submits a report through a structured form capturing indicator type, value, description, severity, TLP level, and a disclosure preference. In the Analyst view, a duty analyst sees a review queue of pending submissions and can approve a report for dissemination or reject it. Approved reports appear in a shared feed visible to all members, with the submitting organization withheld unless disclosure was explicitly permitted. A dashboard view reports program-health metrics — total submissions, approvals, pending items, and contributing organizations — and an emergency broadcast feature allows an analyst to issue a community-wide alert banner for active, urgent threats.

5.3 Key Features Implemented

- Member submission form with indicator type, value, description, severity, and TLP classification.
- Optional disclosure control, sanitizing submitter identity by default.
- Analyst review queue with approve/reject actions that gate dissemination.
- Sanitized, TLP-aware shared feed.
- Emergency broadcast banner for active, urgent threats.
- Live dashboard reporting submission counts, approvals, and contributing organizations.

5.4 User Interface Walkthrough

Figure 3 shows the member-facing submission form. A member selects the indicator type and severity, enters the indicator value and a description of what was observed, chooses a TLP classification, and decides whether to allow their organization's name to be attached to the report.

The screenshot shows the 'Submit a threat report' interface for a member. The left sidebar contains the 'SENTINEL ISAC' logo, a 'MEMBER' button, and a 'WORKFLOW' section with 'Submit report', 'Shared feed', and 'Dashboard' options. The main area is titled 'Submit a threat report' with a subtitle 'Goes to the duty analyst for triage before it reaches the community.' It features a form with the following fields: 'Indicator type' (dropdown menu showing 'IP Address'), 'Severity' (dropdown menu showing 'Medium'), 'Indicator value' (text input with placeholder 'e.g. 185.220.101.47, or a domain, hash, URL...'), and 'Description' (text area with placeholder 'What did you observe, and in what context?'). Below these is a 'Classification (TLP)' section with four buttons: 'TLP:RED', 'TLP:AMBER', 'TLP:GREEN' (which is highlighted), and 'TLP:CLEAR'. A checkbox is present with the text 'Allow the community to see my organization's name attached to this report. Otherwise it's shared as "a member org."'. At the bottom of the form is a 'Submit for review' button. The bottom left corner of the interface shows 'Logged in as Your Org'.

Figure 3. Member view — submitting a threat report.

Figure 4 shows the analyst-facing review queue, with two pending submissions awaiting triage. Each entry displays the indicator, its TLP classification, severity, submitting organization, and timestamp, along with actions to approve and disseminate, or reject.

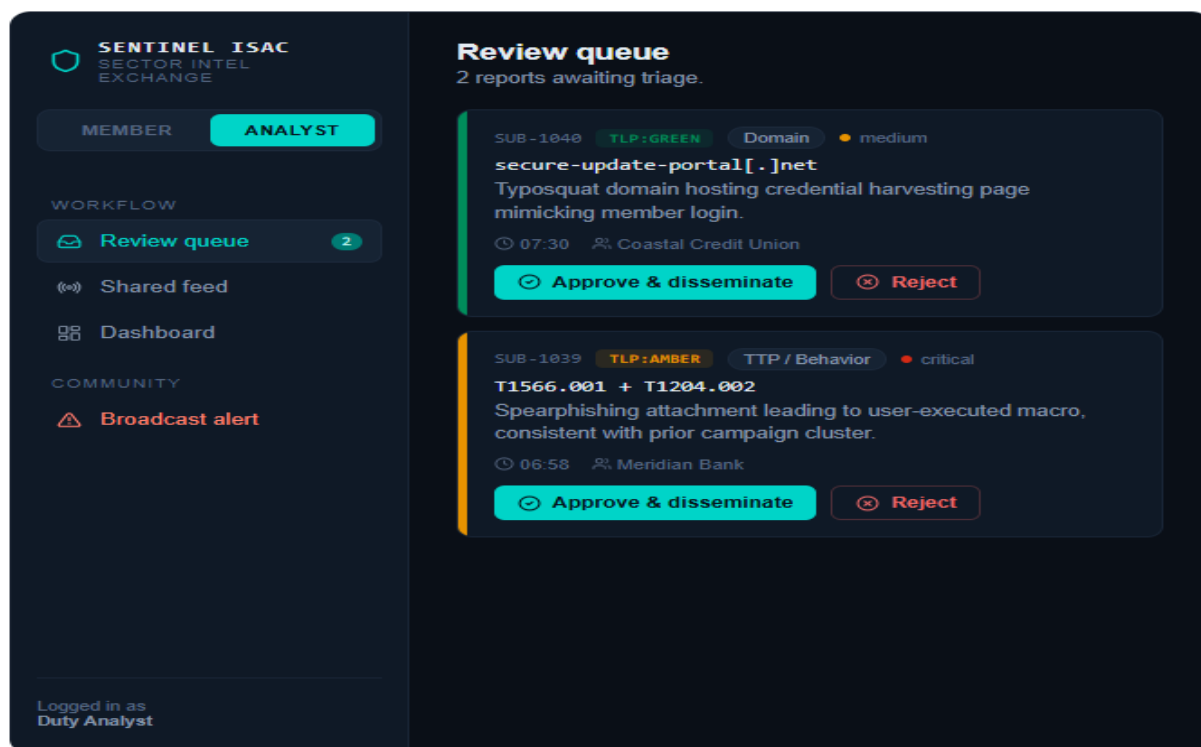


Figure 4. Analyst view — the review queue awaiting triage.

6. Results and Demonstration

6.1 Demonstration Scenario

The reference implementation was exercised through a full lifecycle scenario: a member organization submits a report describing a newly registered phishing domain, classified TLP: AMBER, with disclosure withheld. The report appears in the analyst's review queue. On approval, the report moves to the shared community feed, visible to all members with the submitting organization shown as withheld. The dashboard reflects the updated submission and approval counts immediately.

6.2 Observed Outcomes

The demonstration confirmed that the designed lifecycle functions as intended end-to-end: submission, sanitization, triage, classification, dissemination, and program-health reporting all operate consistently with the design described in Section 4. The TLP classification correctly gated the visibility of the submitting organization's identity, validating the core design goal of allowing disclosure of threat content without forced disclosure of source.

7. Limitations and Future Work

As a prototype, the reference implementation deliberately leaves out several elements that a production deployment would require.

- Legal agreements: signed membership terms covering confidentiality, liability, and antitrust guardrails.
- Automated integration: real SIEM/SOAR integration so shared indicators feed detection rules directly, and full TAXII transport rather than a simulated dissemination step.
- Persistent, multi-tenant backend: the current build holds state in memory for the duration of a session; production use requires durable, access-controlled storage.
- Verified organizational identity: a vetting process governing who may join the community at all.
- Automated redaction: the current disclosure control is a binary submitter choice; a production system would likely combine this with automated detection of identifying detail (internal IP ranges, known organizational domains) within free-text fields.

Future work could extend the prototype with real TAXII 2.1 feed endpoints, integrate a genuine STIX 2.1 validation library rather than a STIX-inspired internal object, and add authentication so that member and analyst roles are cryptographically verified rather than selected via a role switch.

8. Conclusion

This project set out to design, and then demonstrate, a threat intelligence sharing process modelled on real-world ISACs. The resulting design defines a clear governance structure, a six-stage sharing lifecycle, and a TLP-based classification scheme that allows organizations to share what they observed without being forced to disclose who they are. The working reference implementation, Sentinel ISAC, demonstrates that this process can be operationalized in software: submission, sanitization, triage, classification, and dissemination all function together as a coherent workflow.

The central finding of the project is that the technical side of threat sharing is largely a solved problem — STIX, TAXII, and TLP already provide mature, well-adopted standards for structuring, transporting, and classifying shared threat data. What determines whether an ISAC actually succeeds is not the availability of these standards but governance that participants trust, classification that is genuinely respected, and a workflow simple enough that a busy security team will use it under real operational pressure.

References

FIRST.org. Traffic Light Protocol (TLP) Definitions and Usage. Forum of Incident Response and Security Teams.

OASIS Cyber Threat Intelligence Technical Committee. Structured Threat Information eXpression (STIX) Version 2.1.

OASIS Cyber Threat Intelligence Technical Committee. Trusted Automated eXchange of Indicator Information (TAXII) Version 2.1.

FS-ISAC. Financial Services Information Sharing and Analysis Centre.

Health-ISAC. Health Information Sharing and Analysis Centre.